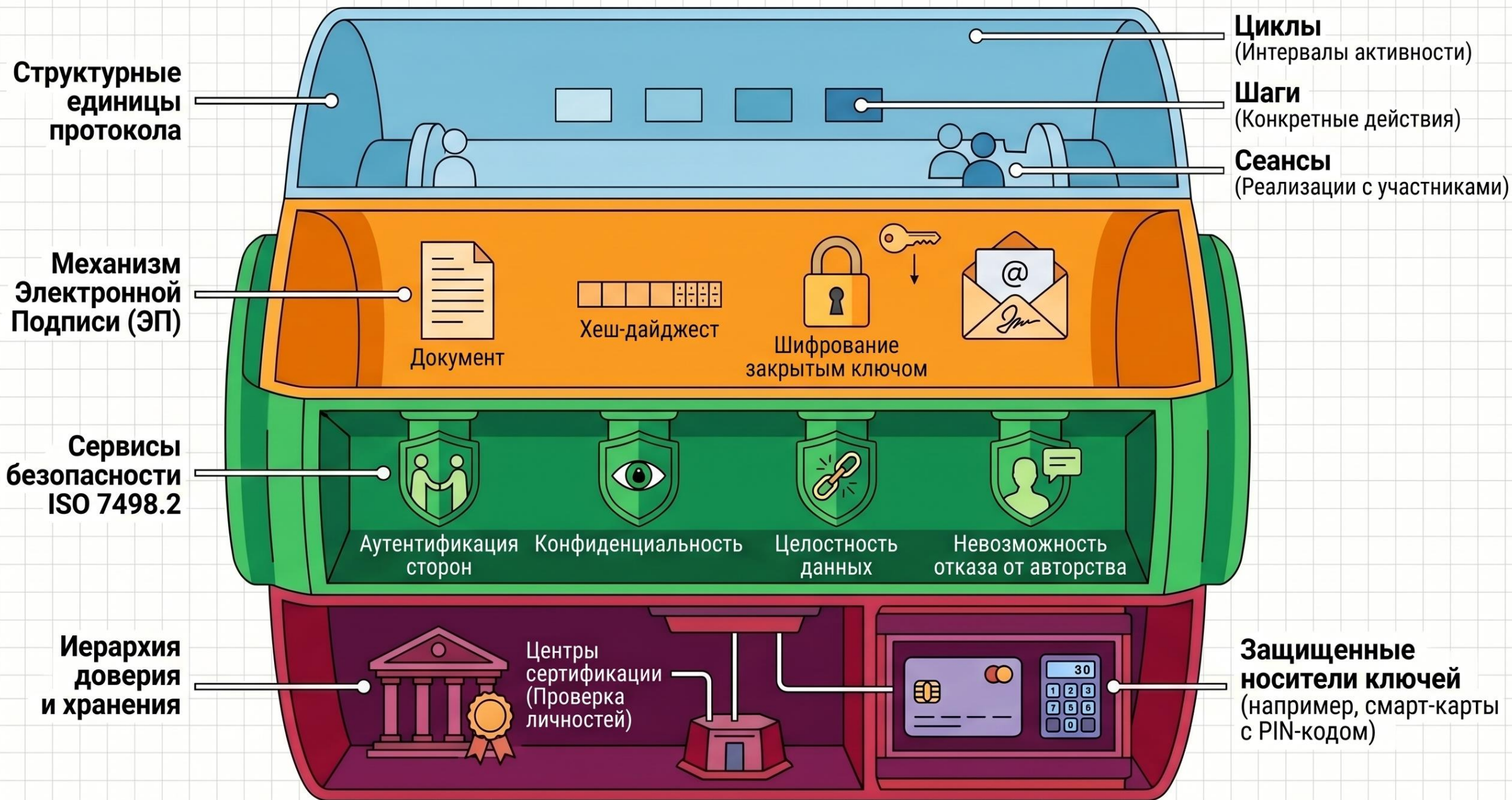
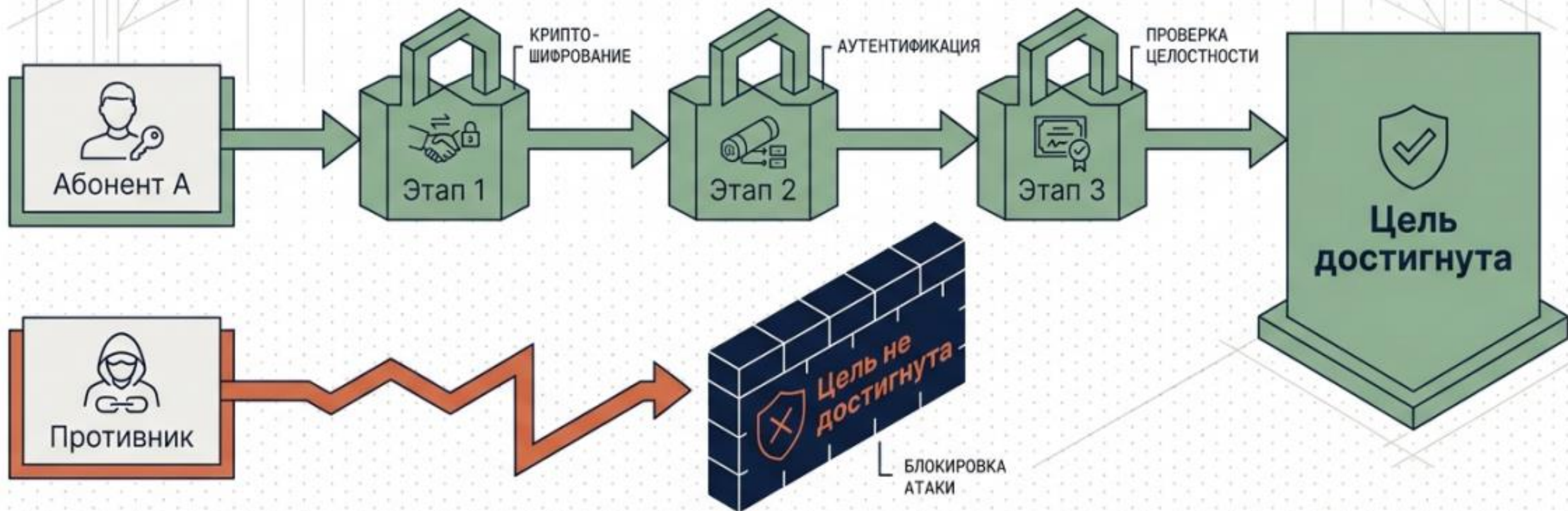


Анатомия Криптографического Протокола



Протокол — это алгоритм взаимодействия абонентов с использованием криптографических средств, где участники достигают своей цели, а их противники — **нет**.



1. Строгий порядок:

Каждое действие выполняется строго в свою очередь.



2. Непротиворечивость:

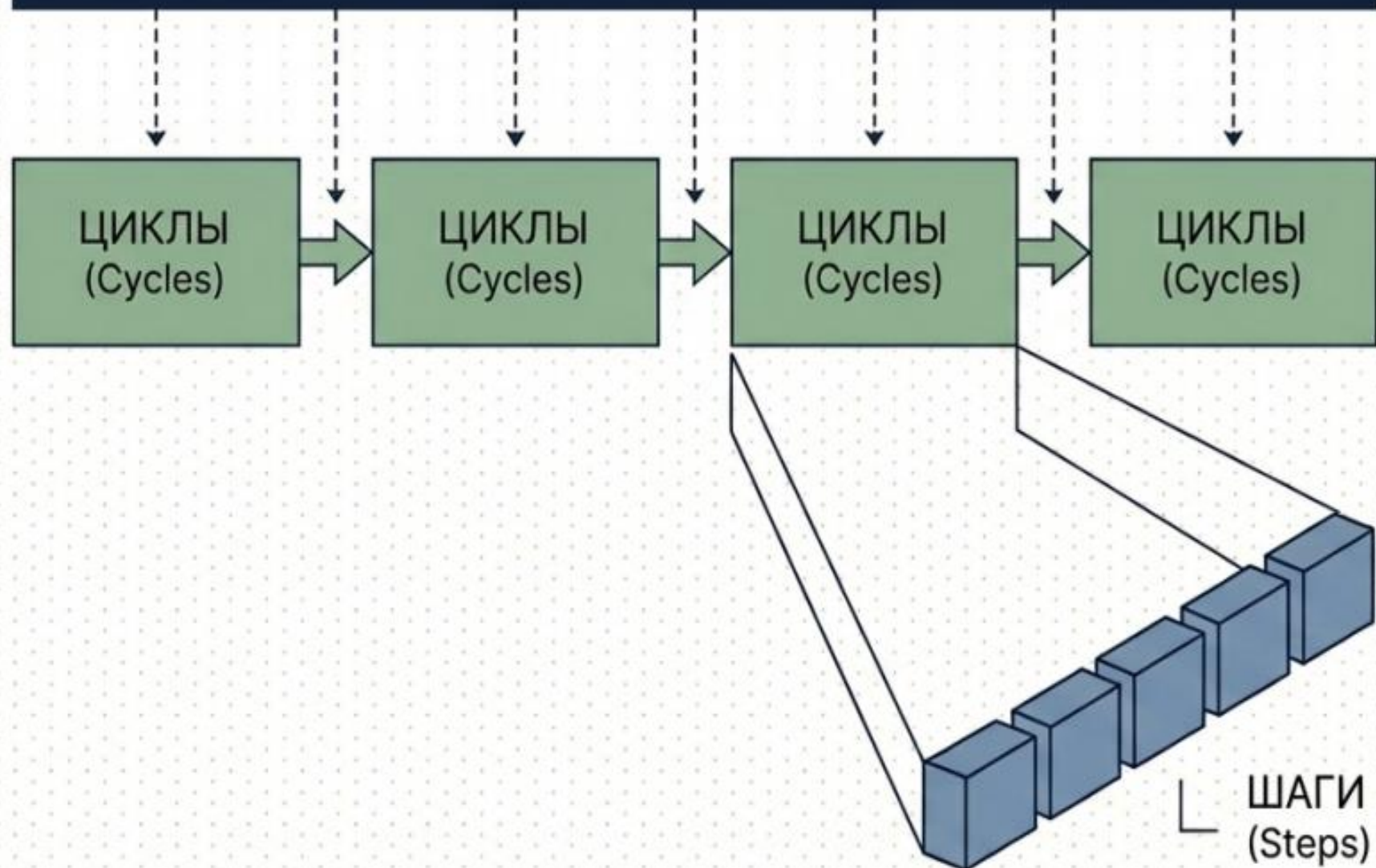
Логика шагов не допускает двойных толкований.



3. Полнота:

Для каждой возможной ситуации предусмотрено соответствующее действие.

СЕАНС (Session)



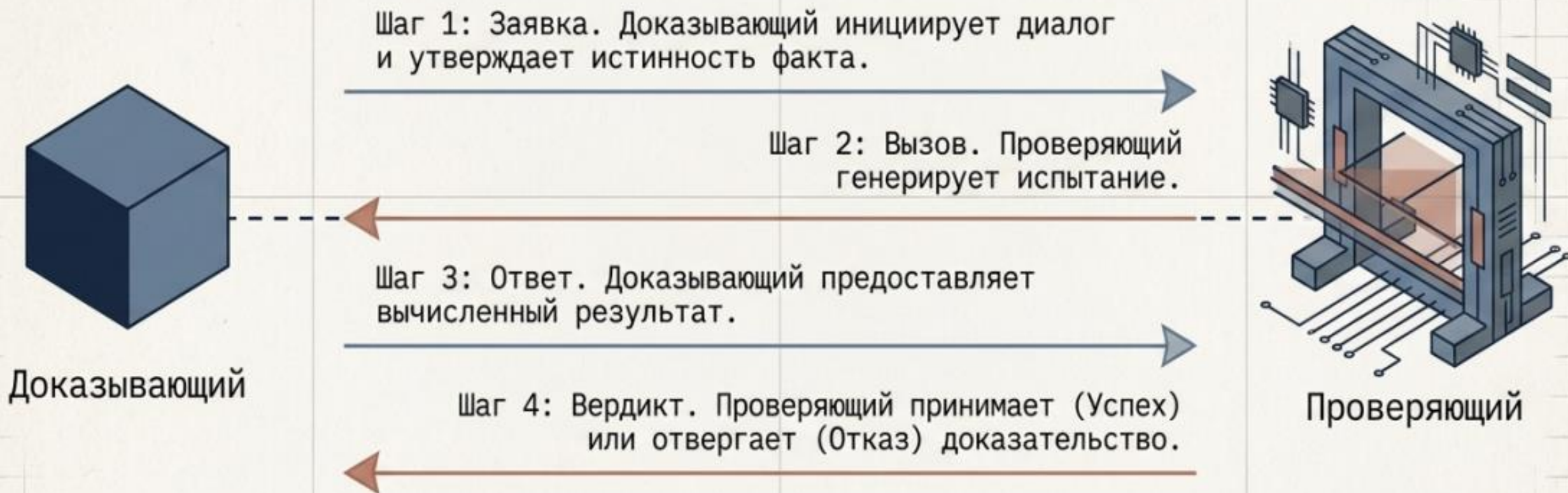
Конкретная реализация протокола с реальными участниками.

Временной интервал между точками синхронизации, в котором активен только ОДИН из участников.

Конкретные законченные действия внутри цикла:

- Вычисление функции
- Проверка сертификата ключа
- Генерация случайного числа
- Отправка сообщения

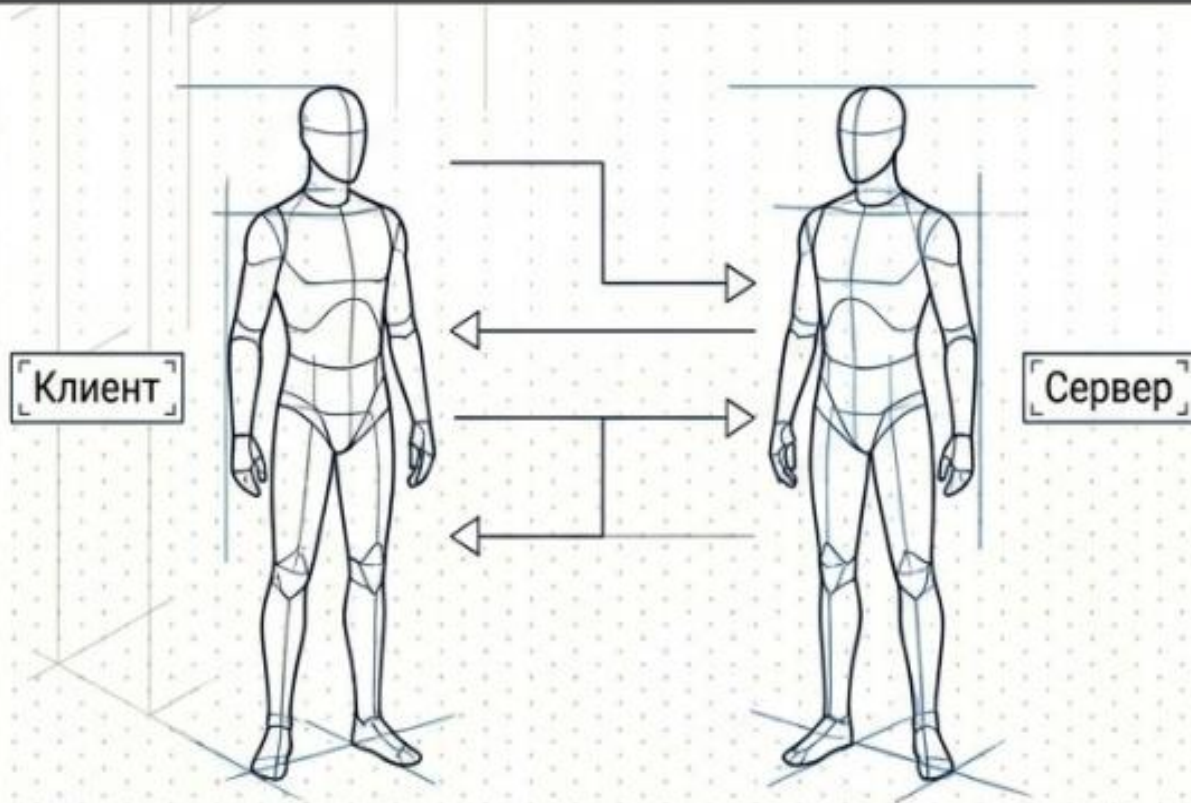
Доверие выстраивается через интерактивное испытание



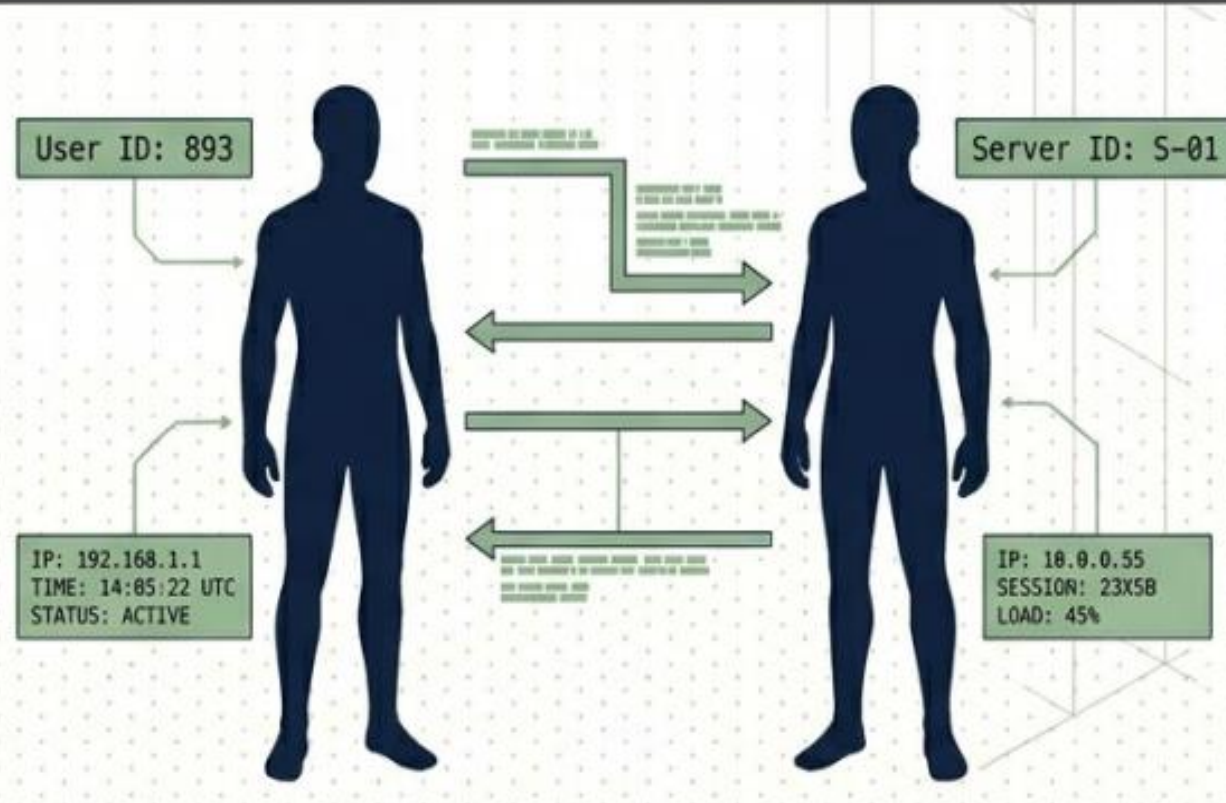
В криптографии доказательство – это не статичный документ, а динамический процесс убеждения.

В теоретических описаниях протоколов фигурируют **Роли**.
В реальных записях сеансов — **Конкретные субъекты**.

РОЛЬ (Функция)

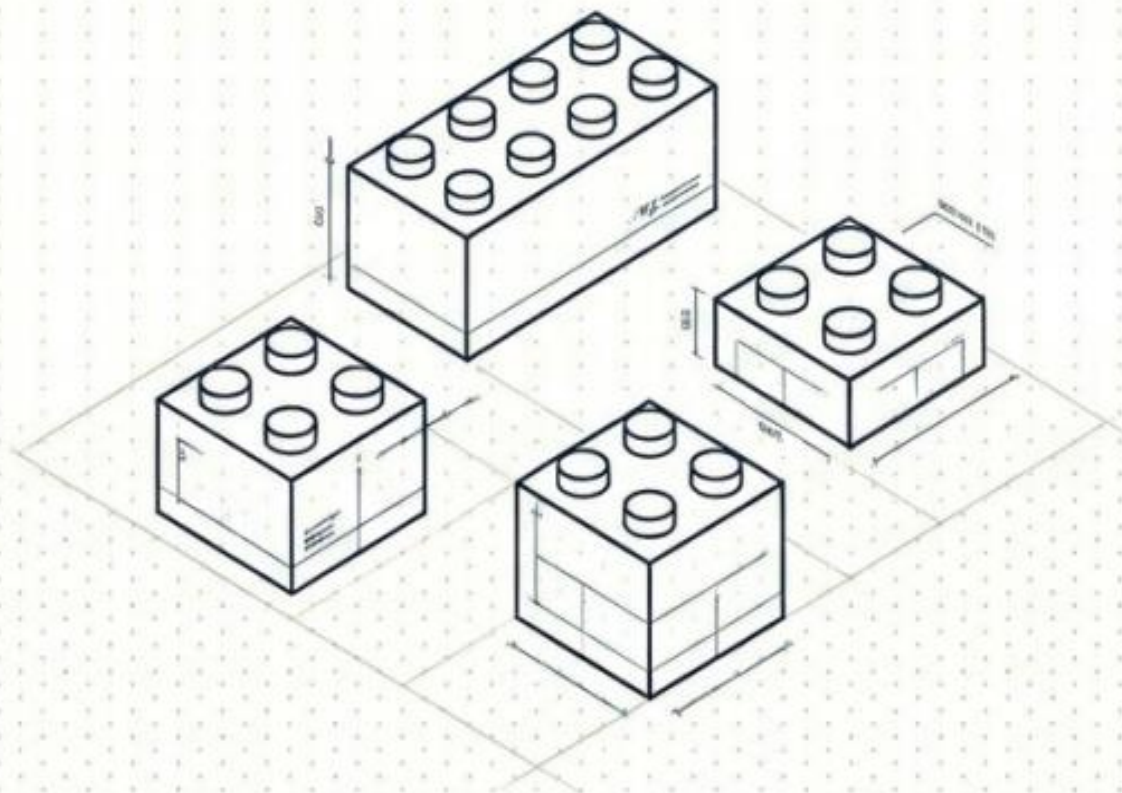


СЕАНС (Исполнение)



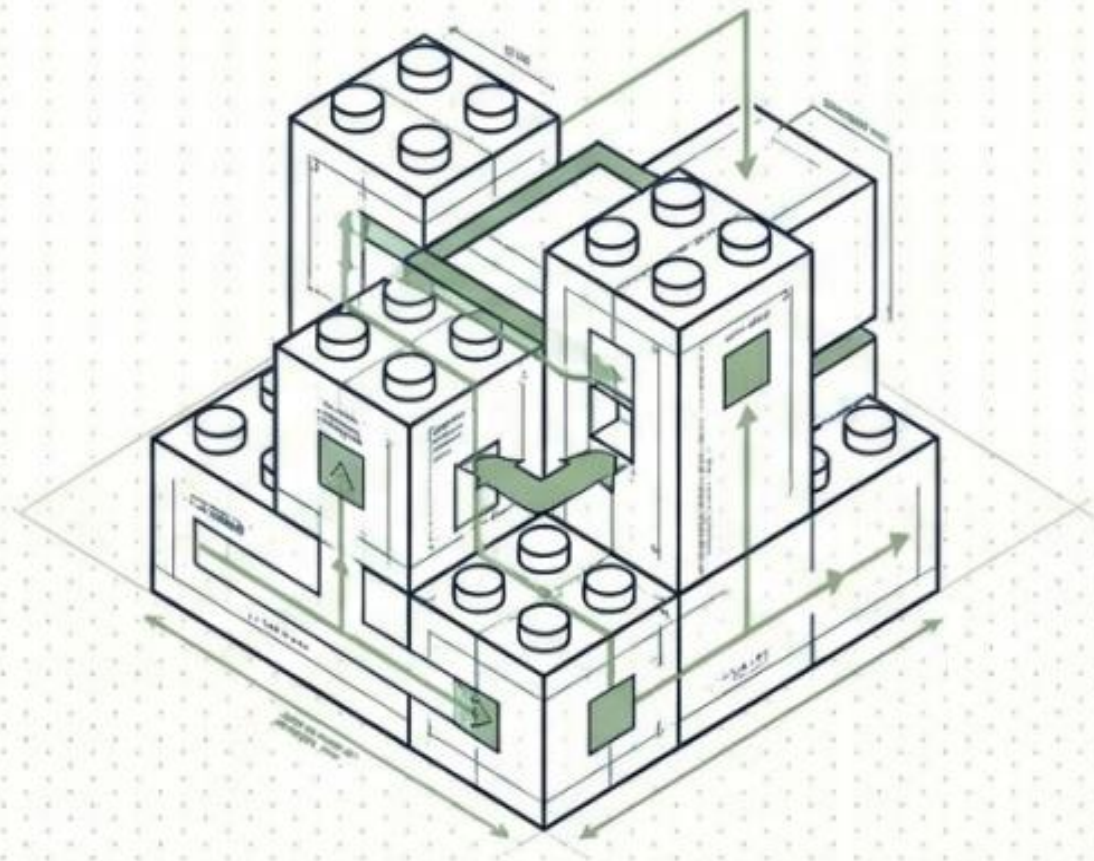
Уязвимость архитектуры: Если противник вмешивается, или участник пытается выступать одновременно в нескольких ролях, возникает нарушение свойств протокола — реализуется сценарий атаки.

Примитивные протоколы



- Решают одну абстрактную задачу
- Не имеют самостоятельной практической пользы
- Служат базовыми строительными блоками системы

Прикладные протоколы



- Решают практические задачи безопасности
- Реализуют сразу несколько криптографических функций
- Представляют собой гибкие семейства с изменяемыми параметрами



Конфиденциальная передача

Двустороннее
шифрование для
защиты от
контроля линии.

Примеры: SCP, SFTP



Аутентификация и Идентификация

Проверка знания
секрета без его
предъявления и
доступ к БД прав.

Пример: LDAP



Распределение ключей

Безопасное
снабжение
участников
секретными
сеансовыми
ключами.



Электронная подпись

Числовое
дополнение для
проверки авторства
(вычисление
и проверка).



Неотслеживаемость

Скрытие источника
пересылки
информации от
стороннего
наблюдения.

Стандарт ISO 7498.2: Функции безопасности (Часть 1)

Аутентификация



Источника данных

Гарантирует, что данные созданы заявленным источником (без защиты от повтора).



Сторон

Гарантирует, что сторона взаимодействия является той, за кого себя выдает (защита от имитации).

Доступ и Приватность



Разграничение доступа

Защита ресурсов системы от несанкционированного использования.



Конфиденциальность

Защита от несанкционированного раскрытия потока данных.

Стандарт ISO 7498.2: Функции безопасности (Часть 2)

Невозможность отказа



Базовая: Невозможность отказа от факта участия в обмене.

Базовая гарантия того, что ни одна из сторон не может отрицать свое участие в процессе коммуникации или обмена данными.



Доказательство получения: Получатель не может отрицать доставку.

Отправитель получает подтверждение того, что данные были успешно доставлены получателю, который не может это опровергнуть.



Доказательство источника: Отправитель не может отрицать отправку.

Получатель может доказать, что данные были отправлены конкретным отправителем, который не может это отрицать.

Целостность



Данных: Проверка отсутствия несанкционированной модификации.

Гарантия того, что данные не были изменены, уничтожены или повреждены во время передачи или хранения.



Соединения (без восстановления): Защита всего потока данных установленного соединения.

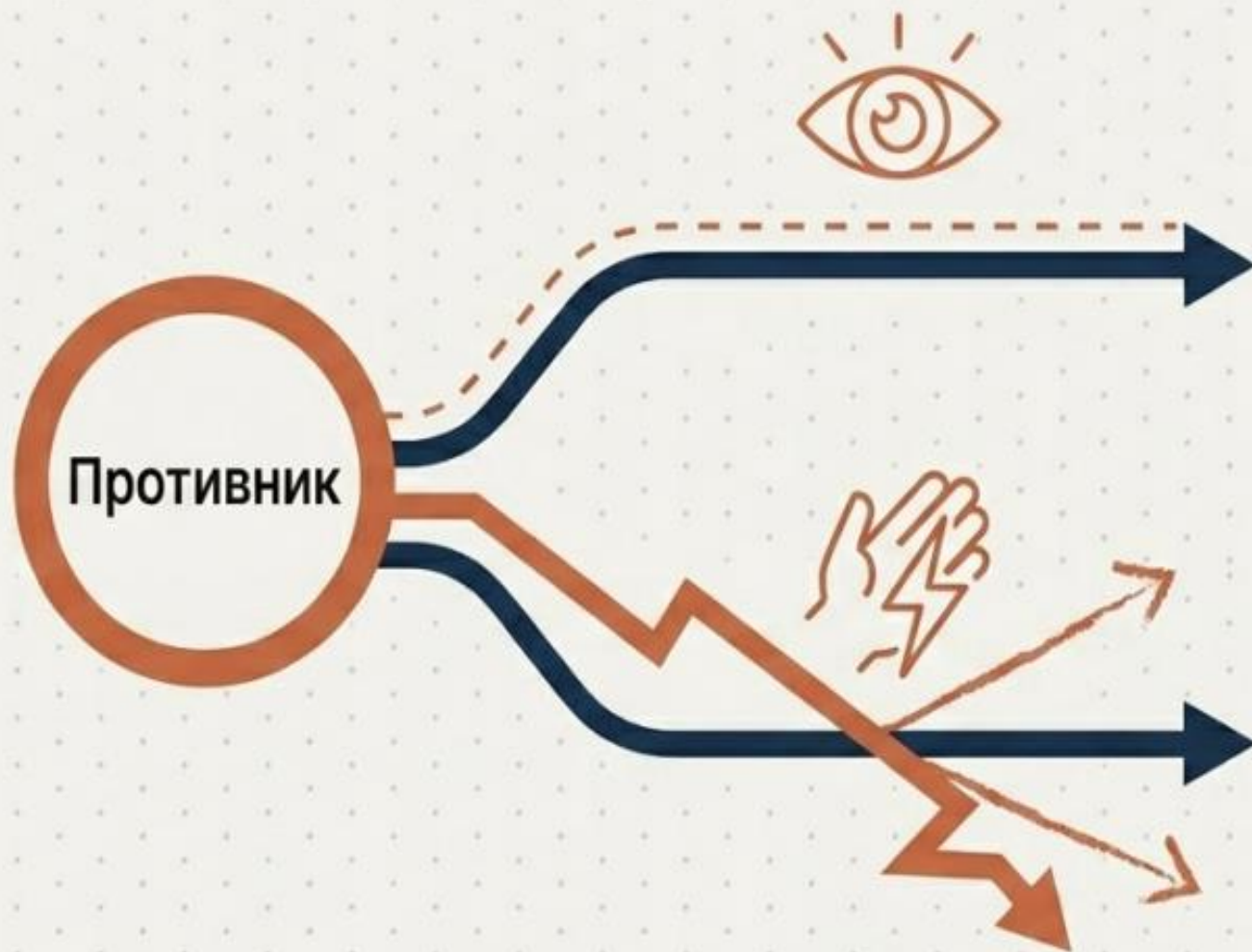
Обеспечение целостности всего потока данных в рамках установленного соединения, с обнаружением любых изменений.



Соединения (с восстановлением): Защита потока с механизмом восстановления модифицированных данных.

Расширенная защита потока данных с функцией автоматического восстановления или повторной передачи в случае обнаружения модификации.

Ландшафт Угроз: Пассивные и Активные Атаки



Пассивная атака (Наблюдение)

Взломщик не вмешивается в протокол.
Цель — извлечь ценную информацию на основе анализа шифртекста.

Активная атака (Вмешательство)

Взломщик изменяет протокол к собственной выгоде.

- Действия: Выдача себя за другого, повторение сообщений, подмена данных, разрыв линии связи, модификация.

Матрица диагностики: Угроза против Защитного механизма

Угроза (Активная атака)		Защитный механизм (Архитектура)	
	Атака «Человек посередине» (MitM): Невозможность проверить прямое общение.		Использование ЭП при обмене сеансовыми ключами; одновременная передача ключей и сообщений.
	Подмена (Spoofing): Имитация пользователя для получения форматов шагов.		Скрытие алгоритмов идентификации; различные форматы сообщений на разных шагах; вставка спецметок.
	Подмена доверенного сервера: Перехват трафика от имени центра генерации.		Привязка ключей к идентификаторам ОБЕИХ взаимодействующих сторон (передача обоих ID в зашифрованном виде).



Угроза (Манипуляция временем)

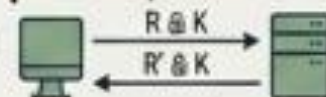
Защитный механизм



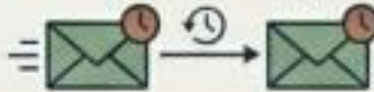
Повторное навязывание (Freshness attack): Повторное использование ранее переданного ключа.



Техника «запрос-ответ» (клиент шифрует случайный запрос сервера общим ключом для проверки).



Воспроизведение сообщений: Пересылка старых сообщений под видом новых.



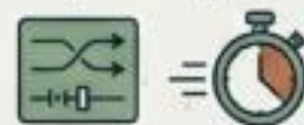
Порядковые номера сообщений; метки даты/времени; уникальные запросы.



Задержка передачи (Forced delay): Перехват и навязывание в более поздний момент.



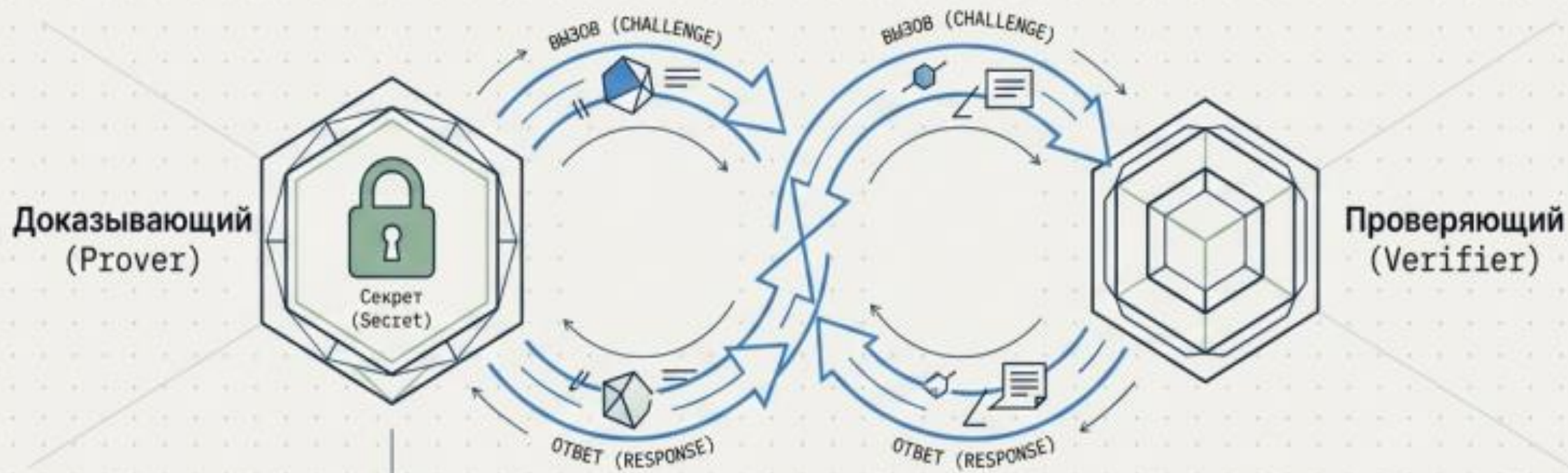
Случайные числа + жесткое ограничение временного промежутка для ответа.



Атака по словарю: Сравнение украденного файла с массивом вероятных зашифрованных паролей.

Интерактивное доказательство: Протокол, где Доказывающий убеждает Проверяющего в истинности утверждения, а тот принимает или отвергает его.

Доказательство знания: Доказывающий доказывает владение секретом, НЕ раскрывая саму секретную информацию.



Вероятностная динамика :

При увеличении числа итераций:

- Если утверждение верно -> вероятность успеха стремится к 1. →
- Если утверждение ложно -> вероятность успеха стремится к 0. →

Золотые метрики протоколов доказательства

Полнота (Completeness)

Свойство алгоритма: если участники действуют честно, протокол ВСЕГДА решает ту задачу, для которой он создан.

Система работает.



Корректность (Soundness)

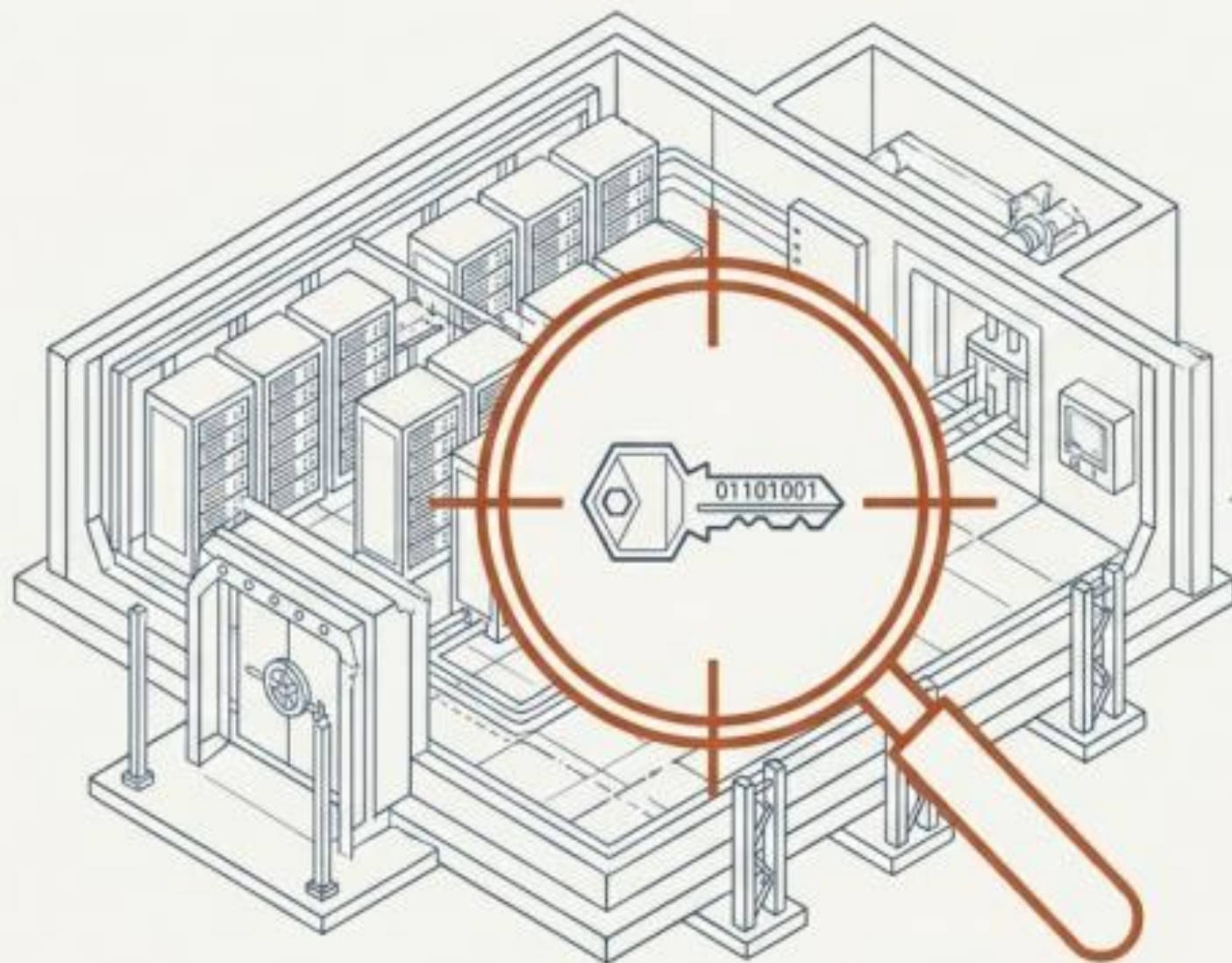
Свойство защиты: способность противостоять противнику, который не располагает секретом, но пытается выдать себя за легитимного участника.

Система безопасна.

Архитектура современного криптографического протокола — это идеальный баланс между гарантированным выполнением задачи и абсолютной устойчивостью к обману.

Безопасность системы — это безопасность ее ключа

Криптографическая стойкость алгоритмов зависит исключительно от ключа, а не от секретности конструкции самой системы. Если злоумышленник может угадать начальные биты, система скомпрометирована.



Три применения случайности

1. Ключи шифрования:

Базовый элемент криптографической защиты.

2. Векторы инициализации (IV):

Стартовые значения для блочных шифров.

3. Одноразовые номера (Nonces):

Гарантия уникальности сеансов связи.

Спектр случайности: Физика против Математики



Физические источники (Аппаратные ГСЧ)

Криптографические ГПСЧ (CSPRNG)

Источник: Тепловой шум резистора / природная энтропия.

Источник: Вычислительные математические алгоритмы.

Скорость: Низкая (может тормозить систему).

Скорость: Высокая (генерация больших объемов данных).

Детерминизм: Нет (истинная непредсказуемость, неперiodичны).

Детерминизм: Да (результат определяется ключом/сидом).

Применение: Строгое шифрование, генерация начальных сидов.

Применение: Воспроизводимые тесты, имитация, повседневная безопасность.

Два правила криптографической стойкости ГПСЧ

Чтобы алгоритм мог применяться в криптографии, он обязан одновременно выполнять два жестких условия. Одно не влечет за собой другое.



Архитектура генератора: Алгоритм Fortuna

Задача: Преодоление проблемы неточной оценки энтропии в классических генераторах.



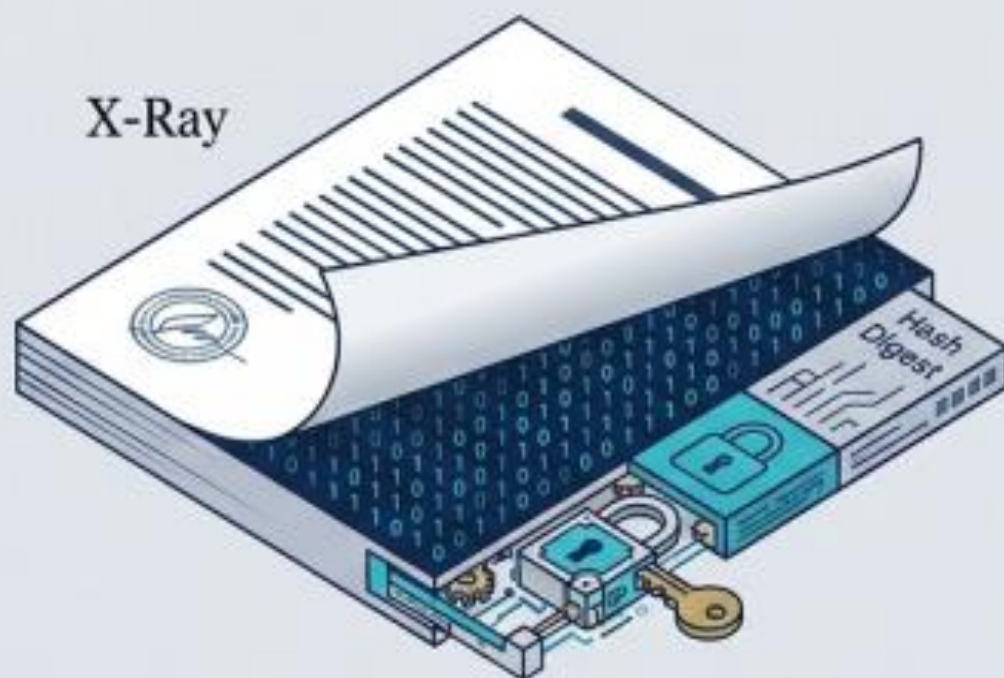
Механизм

1. Сбор шума из различных источников в изолированные пулы энтропии.
2. Хеширование внутреннего состояния генератора с одним из пулов.
3. Генерация блоков вывода с использованием криптографического ядра AES-128.

Уязвимость

Алгоритм генерирует безлимитные последовательности, но критически зависит от качества первичных источников энтропии для своего первоначального заполнения.

Что такое Электронная подпись?



1. Хеширование



Документ преобразуется в дайджест фиксированной длины (решает проблему совместности и скорости).

2. Шифрование



Хеш-дайджест шифруется личным закрытым ключом отправителя.

3. Проверка



Получатель расшифровывает дайджест открытым ключом и сравнивает с новым хешем.

Ключевой инсайт

ЭЦП — это не картинка с вашей росписью.

Это зашифрованные метаданные (дополнение к файлу), неразрывно связывающие конкретный файл с математическим ключом владельца.

Жизненный цикл электронной подписи



Инфраструктура доверия: Удостоверяющие центры (УЦ) и Сертификаты



Уязвимость: Открытый ключ доступен всем. Злоумышленник может подменить его, чтобы выдать себя за другого человека.



Решение: Сертификат открытого ключа. Защищенный файл данных, удостоверяющий связь между личностью владельца и его ключом.

Роль Удостоверяющего центра

- ⊖ **Администратор доверия:** Идентифицирует заявителя и заверяет его сертификат своей цифровой подписью.
- ⊖ **Жизненный цикл ключа:** Формирование -> Хранение -> Обслуживание -> Отзыв (при компрометации).
- ⊖ **Примечание:** Выдавать квалифицированные сертификаты (КЭП) могут только аккредитованные центры (ФНС, Казначейство).

Уязвимость системы: Хранение закрытого ключа

Злоумышленник с закрытым ключом может создать действительную подпись от лица пользователя. Ответственность несет сам владелец (63-ФЗ).



Почему смарт-карты?

Закрытый ключ никогда не покидает карту. Процессор смарт-карты сам подписывает хеш внутри чипа. Создать копию ключа невозможно.

Правовой каркас: Стандарты ЭП (ФЗ-63)

Простая (ПЭП)	Неквалифицированная (НЭП)	Квалифицированная (КЭП)
Технология: Коды, логины и пароли.	Технология: Криптографическое преобразование.	Технология: Криптография + Квалифицированный сертификат.
Функция: Подтверждает только факт формирования подписи лицом. Нет криптографии.	Функция: Определяет лицо и обнаруживает изменения файла.	Статус: Абсолютный аналог рукописной подписи. Работает везде по умолчанию.
	Статус: Юридическая сила только при наличии дополнительного соглашения сторон.	

Обезличенная ЭП

Без личных данных, аналог печати юридического лица. Применяется для автоматического подписания в информационных системах.

Классификация подписей:

Простая Электронная Подпись (ПЭП)



Уровень безопасности



Юридическая сила



1 | Механизм

Подтверждает личность через коды, пароли или авторизацию в системе. Криптографические ключи пользователю не выдаются.

2 | Область применения

Банковские приложения, порталы услуг (до подтверждения личности), внутренние системы предприятий.

Ключевой инсайт

ПЭП — самый массовый, но наименее защищенный вид подписи. Она не защищает документ от изменений после подписания и непригодна для критически важных юридических документов.

Классификация подписей: Усиленная Неквалифицированная Подпись (НЭП)

Уровень безопасности



Юридическая сила



1 Механизм

Использует асимметричную криптографию (закрытый и открытый ключи). Позволяет обнаружить факт внесения изменений в документ.

2 Юридическая сила

Имеет вес только при наличии предварительного дополнительного соглашения между сторонами о признании такой подписи.

Ключевой инсайт

НЭП обеспечивает надежную криптографическую защиту целостности, но не имеет автоматической силы закона.

Идеальна для внутреннего корпоративного документооборота B2B-партнерств по договору.

Золотой стандарт: Квалифицированная Электронная Подпись (КЭП)

Уровень безопасности



Юридическая сила



Абсолютная

USB Token / Smart Card
(Touch-Memory)



2FA PIN-pad

Механизм

1

Ключ на защищенном носителе
(двухфакторная аутентификация через PIN).
Инструменты шифрования
сертифицированы ФСБ РФ (Приказ №796).

Юридическая сила

2

ФЗ №63 полностью приравнивает КЭП к
собственноручной подписи прямого действия
без дополнительных условий.

Ключевой инсайт

Это «тяжелая
артиллерия»
цифрового мира.

Квалифицированный
сертификат
автоматически
признается везде:
от судов до
международных
сделок (например,
взаимное признание
ЭП между РФ
и Беларусью).

Автоматизация: Обезличенная электронная подпись



1 Суть

Специализированный инструмент для юридических лиц. Не содержит персональных данных (ФИО) конкретного сотрудника.

2 Применение

Автоматическое подписание и проверка тысяч документов в минуту внутри информационных систем (квитанции, логи, массовые рассылки).

3 Ограничения

Нельзя использовать для участия в госзакупках или вне интегрированных информационных систем.

Ключевой инсайт

Обезличенная ЭЦП отделяет человеческую идентичность (конкретного сотрудника) от корпоративной идентичности (организации), позволяя автоматизировать колоссальные объемы рутины.

Единая архитектура цифрового доверия

Энтропия



ГПСЧ



Ключ



Хеш



УЦ



КЭП



Источник

Криптографическая надежность начинается с непредсказуемой энтропии и качественных ГПСЧ, создающих стойкие закрытые ключи.

Механизм

Эти ключи обеспечивают работу асимметричного шифрования и хеширования, позволяя защитить файл от любых модификаций.

Инфраструктура

Подкрепленная Удостоверяющими центрами и жесткими стандартами, математика превращается в квалифицированную электронную подпись (КЭП).

Случайность генерирует ключ. Математика защищает документ. Закон гарантирует доверие.

ОСНОВЫ КРИПТОГРАФИИ

Лекция № 1. Введение в криптографию

Основные понятия, терминология ГОСТ и цели защиты информации

Загрузить

